

Data Security (EDU-220)

This course provides a detailed overview of Zscaler's Data Security capabilities within the Zero Trust Exchange platform. It covers key components of the Data Security suite and guides you through the configuration and monitoring of policies to protect sensitive data and ensure compliance.

Introduction to Data Security

Zscaler Data Security Overview

- Massive data breaches are driven by targeted attacks, insider risks, accidental exposure, generative AI misuse, and misconfigurations.
- Traditional data security involves fragmented tools (DLP, CASB, endpoint policies), causing inefficiency, blind spots, and inconsistent management.
- Zscaler unifies data protection across motion, rest, endpoints, BYOD, and SaaS applications through a single platform, simplifying enforcement and reducing complexity.
- Key features include Web/Email DLP, Endpoint DLP, DSPM, browser isolation, and real-time visibility for proactive incident handling and secure productivity.

AI-driven Auto Data Discovery and Classification:

- AI-driven inline discovery identifies sensitive data categories leaving the organization with visibility into users, destinations, and behavior patterns (sanctioned vs unsanctioned).
- Endpoint scanning flags sensitive files at the device level, revealing high-risk users and data categories like PII.
- Cloud discovery analyzes storage patterns to identify risks based on predefined themes (GLBA, PCI, HIPAA).
- Insights enable automated enforcement and proactive mitigation, eliminating manual DLP setup challenges.

Secure Data in Motion

Zscaler uses the following advanced data protection capabilities to secure data in motion.

Shadow IT & Data Discovery

Shadow IT Discovery identifies unsanctioned cloud applications within the organization and maintains an application database of about 45,000 cloud applications, each tagged with a risk score.

Applications are analyzed for threat (encryption methods, SSL channels, port evasion) and hosting characteristics (certifications, terms & conditions), with customizable risk scores based on the customer's environment, enabling blocking of high-risk applications and specific activities within applications using granular policies.

Cloud App Control

Cloud App Control recognizes and categorizes 50,000 cloud applications into 16 categories.

Beyond URL analysis, deep inspection includes payloads and HTML content, allowing granular policy enforcement to control specific activities within applications (e.g., allowing Dropbox use but blocking sensitive data uploads), focusing on user activities rather than content inspection.

Tenant Restrictions

Tenant restriction differentiates between personal and corporate accounts within the same application.

Allows full access to corporate accounts while restricting activities on personal accounts, applies granular policies to different instances of the same tenant, and is useful for organizations with multiple instances due to acquisitions or partnerships.

Zscaler DLP Policies

Zscaler uses two types of DLP policies for comprehensive data protection:

Content-driven policies inspect actual data content, such as keywords, patterns, or file types, to identify sensitive information like credit card numbers or confidential documents across supported channels.

Context-driven policies focus on the circumstances of data usage or movement, applying security measures based on how and where data is accessed or transferred. Together, these approaches effectively mitigate risks and prevent data loss.

Advanced Content Inspection Capabilities

Zscaler offers several advanced inspection capabilities including Optical Character Recognition (OCR) powered by ML and AI, enhanced data security and hygiene through AIP integrations, User and Entity Behavior Analytics (UEBA), and adaptive access.

Optical Character Recognition (OCR): OCR, powered by ML and AI, extracts sensitive data from handwritten text, image files, and screenshots, and enforces DLP policies to protect this data.

Microsoft Azure Information Protection (AIP) Integration: Zscaler integrates with Microsoft AIP to read and enforce labels on documents, allowing policies to block uploads to unsanctioned services and label sensitive documents for encryption and rights management.

User and Entity Behavior Analytics (UEBA) and Adaptive Access: UEBA uses ML and AI to detect anomalous user behavior, triggering adaptive access actions such as multifactor authentication or account reauthentication to protect sensitive data.

Unified DLP Engine: Zscaler's unified DLP engine applies consistent policies across web traffic, SaaS applications, public cloud infrastructure, private applications, and endpoint data, including USB transfers and email traffic, ensuring comprehensive data protection.

UEBA Alerts: Real-time UEBA Alerts detect and notify of anomalous activities, focusing on insider threats, compromised credentials, and Advanced Persistent Threats (APTs) that may bypass traditional security measures, while providing benefits such as easy management and customization, continuous security event evaluation, centralized tracking with high-level statistics, and advanced analytics to identify anomalies against baseline behavior patterns.

Parallel Policy Processing: Zscaler's DLP policies provide granular control with numerous exceptions and leverage parallel policy processing, unlike traditional firewalls and proxies, to ensure all policies are evaluated and stricter rules are applied, enhancing security by preventing potential security holes.

Zscaler outbound Email DLP: Zscaler Outbound Email DLP prevents sensitive data exfiltration by enforcing policy rules on outbound email content to external domains, using the same policy tools across all channels to reduce the need for multiple DLP solutions, and allows granular policy enforcement by blocking sensitive information for specific recipients while allowing it for others.

Generative AI Security

Zscaler's Gen AI Security safeguards sensitive data by enforcing DLP rules to restrict sharing via generative AI apps like ChatGPT and Grammarly, while detailed reports track AI usage, trends, and sensitive data interactions by users and departments. It provides contextual visibility into prompt and data categories (e.g., PII, PCI), enabling better risk management. Features like Cloud App Control and Browser Isolation help admins manage access to AI tools, ensuring secure interactions, while URL Filtering controls web access to generative AI platforms for safe, policy-compliant usage.

Secure SaaS Data

Discovery of Third-party Apps: This lesson covers advanced use cases for scanning data at rest, demonstrating the discovery of third-party apps and detailed coverage of 'App Total Security' through integration with various SaaS applications to protect your data at rest.

Out-of-Band CASB and Protection: Zscaler's out-of-band CASB and data protection utilize deep API integration with supported applications (e.g., Office 365, Google Apps, Salesforce, Box, Dropbox, and public cloud infrastructures like GitHub, Azure Blob, and GCP storage) to prevent data loss and address known and unknown threats.

Data at Rest Scanning: The same DLP policies used for in-line scanning are applied to data at rest, identifying and protecting sensitive assets, preventing data exposure during collaboration, and scanning for malware, with retro and iterative scans triggering real-time remediation actions.

AppTotal Security: AppTotal Security addresses the discovery, analysis, and remediation of third-party apps that integrate with SaaS platforms, identifying potentially hazardous apps and managing their permissions to protect data across various environments.

Discovery of Third-Party Apps: The solution vets new integrations, inventories all add-ons and permissions, continuously monitors integration activities, and automates remediation actions, ensuring secure connections between IT-approved platforms and third-party apps.

AppTotal Technology works through API integrations to discover apps, performs static analysis, sandbox testing, and heuristic analysis to identify malicious behaviors, and supports remediation steps like end-user review, permission revocation, and app banning. Users are notified through channels like Slack or email when they grant app permissions, with options to block or revoke access based on security policies.

Secure Cloud Data

Data Security Posture Management (DSPM) enables the discovery, classification, and continuous monitoring of sensitive data across all cloud environments, ensuring only authorized access through least-privilege policies, and assessing data security posture to identify vulnerabilities and provide real-time alerts and recommendations for risk mitigation. DSPM offers a comprehensive inventory of data assets, visibility into data types and locations, and tools for detailed risk assessment and remediation, thereby simplifying cloud data protection and reducing traditional security complexities.

Secure Endpoint Data

Block Sensitive Data Upload

Creating a rule to block sensitive data uploads involves setting criteria like file type, size, and user group in the ZIA portal, selecting actions such as blocking uploads to personal cloud storage, and providing end-user notifications and file quarantine details, ensuring that sensitive files are protected while non-sensitive files can be uploaded successfully.

User Confirmation

User Confirmation within ZIA Admin Portal enforces DLP rules by requiring users to justify or cancel the printing of Personally Identifiable Information (PII) data, providing flexibility and education while maintaining administrative visibility, thus allowing necessary business workflows without compromising data security.

Dashboard and Reports

The dashboard and reports for DLP rules enforcement provide real-time insights and detailed breakdowns of incidents, top users, actions, and severity, allowing administrators to drill down for more information, while the Endpoint DLP Report offers daily updates on end-user activities with sensitive data, such as printing, saving to removable storage, and uploading to cloud accounts, enhancing visibility and analysis capabilities.

Secure Unmanaged Assets (BYOD)

Secure Access with Browser Isolation and PRA

Implementing browser isolation alongside Zscaler Privileged Remote Access (PRA) allows secure access to web applications from unmanaged devices, reducing reliance on VDIs and ensuring that unmanaged endpoints do not compromise application security.

Managing SaaS and Private App Access

Organizations can grant access to SaaS and private applications through an isolated cloud-based browser, directing traffic through Zscaler Internet Access (ZIA) and Zscaler Private Access (ZPA) to enforce security and DLP policies, similar to managed devices with a Zscaler client connector.

Mitigating Data Leakage Risks

By using browser isolation and PRA, organizations can control data exfiltration by limiting file downloads and clipboard access, thereby reducing the risk of data leaks from unmanaged devices and enhancing overall data security.

Incident Management Capabilities

Incident management involves identifying, analyzing, and resolving critical incidents that disrupt normal operations, with Zscaler providing tools for managing DLP and CASB (SaaS Security API) alerts through browser-based notifications, Slack, Teams, and Zscaler Client Connector.

User and Administrative Actions: Users can be notified and required to justify actions through customized notifications, enabling a feedback loop, while administrators can handle incidents via email notifications, Secure ICAP protocol, and integrating real-time logs with SIEM tools like Splunk and QRadar.

Incident Workflow and Automation: Zscaler supports seamless incident management by integrating with ServiceNow for automated ticket creation, on-premises incident receivers for archiving, and full workflow automation to escalate violations to relevant personnel, ensuring comprehensive incident resolution and tracking.

Zscaler Workflow Automation

Zscaler Workflow Automation streamlines data protection workflows by automating incident management, enabling quick remediation of data protection incidents.



The capability automatically groups incidents based on various attributes related to the originating user, the user's manager, and the triggering activity or policy, facilitating more efficient incident handling.